Vulnerability Scan Report

Riverbend Unified School District (fictitious)

Scan name	RUSD-Q4-2026 Internal + External	**Scanner**	Nessus Professional 10.8
Policy	Advanced Network Scan (credentialed)	**Scan window**	2026-10-27 18:02 - 23:47 PT
Targets	10.20.0.0/16 (sampled), 203.0.113.0/26	**Hosts alive**	57

Critical	High	Medium	Low
16	11	9	5
15 in CISA KEV	8 in CISA KEV	1 in CISA KEV	0 in CISA KEV

Counts are unique plugins, not host instances. Informational plugins are omitted.

Hosts with findings

IP / Range	Hostname	Operating system / software	Role
203.0.113.10	fw-do01.riverbendusd.local	FortiOS 7.2.6 (FortiGate 200F)	District office perimeter / SSL VPN
203.0.113.25	vdi-gw01.riverbendusd.local	NetScaler ADC 13.1-48.47	Remote desktop gateway
203.0.113.40	fw-ae01.riverbendusd.local	SonicOS 7.0.1-5030 (TZ470)	Adult Education Center firewall
10.20.0.1	core-sw01.riverbendusd.local	Cisco IOS XE 17.6.4	District core switch
10.20.1.10	RB-DC01	Windows Server 2016	Domain controller
10.20.1.11	RB-DC02	Windows Server 2012 R2	Domain controller
10.20.1.20	RB-EXCH01	Windows Server 2016 / Exchange 2016 CU23	Hybrid mail relay
10.20.1.25	RB-SP01	Windows Server 2019 / SharePoint Server 2019	Staff intranet
10.20.1.30	RB-WSUS01	Windows Server 2019	Patch distribution (WSUS)
10.20.1.40	RB-PRINT01	Windows Server 2016	Print server / PaperCut MF
10.20.1.50	rb-app02	Ubuntu 20.04 LTS	Facilities work-order app (Tomcat)
10.20.1.60	RB-VBR01	Windows Server 2019	Veeam Backup & Replication
10.20.1.70	RB-RMM01	Windows Server 2019	ConnectWise ScreenConnect (help desk)
10.20.1.80	rb-web01	Ubuntu 22.04 LTS	Public website reverse proxy (nginx)
10.20.2.15	RB-HVAC-WS	Windows Server 2008 R2	HVAC / energy management console
10.20.3.12	RHS-WEB01	Windows 10 22H2 (XAMPP)	Teacher-run class website, Riverbend HS
10.20.5.0/24	STAFF-xxxx (41 hosts)	Windows 11 23H2 / Windows 10 22H2	Staff workstations, district office

Findings index

#	Severity	Plugin	Name	CVSS	KEV	Hosts
1	Critical	156014	Apache Log4Shell RCE Detection via Path Enumeration (Direct Check)	10.0	Yes	1
2	Critical	140657	Netlogon Elevation of Privilege Vulnerability (Zerologon) (Remote)	10.0	Yes	1
3	Critical	125313	Microsoft RDP RCE (CVE-2019-0708) (BlueKeep) (uncredentialed check)	9.8	Yes	1
4	Critical	108797	Unsupported Windows OS (remote)	10.0	-	2
5	Critical	190117	Fortinet FortiOS SSL VPN Out-of-Bounds Write (FG-IR-24-015)	9.8	Yes	1
6	Critical	183026	Citrix NetScaler ADC and Gateway Information Disclosure (CTX579459) (Citrix Bleed)	9.4	Yes	1
7	Critical	206797	SonicWall SonicOS Improper Access Control (SNWLID-2024-0015)	9.3	Yes	1
8	Critical	183891	Cisco IOS XE Software Web UI Privilege Escalation (cisco-sa-iosxe-webui-privesc-j22SaA4z)	10.0	Yes	1
9	Critical	174150	PaperCut NG/MF Multiple Vulnerabilities (ZDI-CAN-18987)	9.8	Yes	1
10	Critical	190890	ConnectWise ScreenConnect < 23.9.8 Multiple Vulnerabilities	10.0	Yes	1
11	Critical	207999	Veeam Backup and Replication Deserialization RCE (KB4649)	9.8	Yes	1
12	Critical	172529	Security Updates for Microsoft Outlook (March 2023)	9.8	Yes	9
13	Critical	242281	Microsoft SharePoint Server Deserialization RCE (ToolShell)	9.8	Yes	1
14	Critical	270115	Windows Server Update Service (WSUS) Remote Code Execution (October 2025 OOB)	9.8	Yes	1
15	Critical	233431	Apache Tomcat 9.0.0.M1 < 9.0.99 Partial PUT RCE	9.8	Yes	1
16	Critical	200162	PHP 8.1.x < 8.1.29 CGI Argument Injection (Windows)	9.8	Yes	1
17	High	97833	MS17-010: Security Update for Microsoft Windows SMB Server (ETERNALBLUE)	8.8	Yes	1
18	High	151440	Windows Print Spooler Remote Code Execution (PrintNightmare)	8.8	Yes	3
19	High	165703	Microsoft Exchange Server Multiple Vulnerabilities (ProxyNotShell)	8.8	Yes	1
20	High	201218	OpenSSH < 9.8 RCE (regreSSHion)	8.1	-	1
21	High	268447	Windows SMB Client Improper Access Control (October 2025)	8.8	Yes	14
22	High	214985	7-Zip < 24.09 Mark-of-the-Web Bypass	7.0	Yes	22
23	High	241640	RARLAB WinRAR < 7.12 Directory Traversal	7.8	Yes	6
24	High	201944	Windows MSHTML Platform Spoofing (July 2024)	7.5	Yes	3
25	High	187100	HTTP/2 Rapid Reset Denial of Service	7.5	Yes	1
26	High	42873	SSL Medium Strength Cipher Suites Supported (SWEET32)	7.5	-	3
27	High	41028	SNMP Agent Default Community Name (public)	7.5	-	3
28	Medium	57608	SMB Signing not required	5.3	-	45
29	Medium	211469	Windows NTLM Hash Disclosure Spoofing (November 2024)	6.5	Yes	3
30	Medium	51192	SSL Certificate Cannot Be Trusted	6.5	-	4
31	Medium	104743	TLS Version 1.0 Protocol Detection	6.5	-	4
32	Medium	42263	Unencrypted Telnet Server	6.5	-	1
33	Medium	187315	SSH Terrapin Prefix Truncation Weakness	5.9	-	3
34	Medium	12085	Apache Tomcat Default Files	5.3	-	1
35	Medium	11213	HTTP TRACE / TRACK Methods Allowed	5.3	-	2
36	Medium	12217	DNS Server Cache Snooping Remote Information Disclosure	5.3	-	2
37	Low	153953	SSH Weak Key Exchange Algorithms Enabled	3.7	-	2
38	Low	71049	SSH Weak MAC Algorithms Enabled	2.6	-	1
39	Low	70658	SSH Server CBC Mode Ciphers Enabled	2.6	-	2
40	Low	26194	Web Server Transmits Cleartext Credentials	2.6	-	2
41	Low	10114	ICMP Timestamp Request Remote Date Disclosure	2.1	-	3

Critical findings

1. Apache Log4Shell RCE Detection via Path Enumeration (Direct Check) — CRITICAL | CVSS 10.0

Plugin ID	156014	**CVE**	CVE-2021-44228
Affected	10.20.1.50 (rb-app02) tcp/8080		
CISA KEV	**CVE-2021-44228**: added 2021-12-10, federal due date 2021-12-24	Known ransomware use	
Description	The remote host has a version of Apache Log4j 2 earlier than 2.15.0 bundled with a Java application. JNDI features in configuration, log messages, and parameters do not protect against attacker-controlled LDAP and other JNDI endpoints. An unauthenticated attacker who can get a crafted string logged can execute arbitrary code.		
Solution	Upgrade Apache Log4j to 2.17.1 or later (2.12.4 for Java 7, 2.3.2 for Java 6). If the vendor of the bundled application has not released a fixed build, remove the JndiLookup class from the classpath and restrict outbound LDAP/RMI from the server.		

Plugin output	`Path : /opt/workorder/lib/log4j-core-2.14.1.jar`
	`Installed version : 2.14.1`
	`Fixed version : 2.17.1`		

2. Netlogon Elevation of Privilege Vulnerability (Zerologon) (Remote) — CRITICAL | CVSS 10.0

Plugin ID	140657	**CVE**	CVE-2020-1472
Affected	10.20.1.11 (RB-DC02) tcp/445		
CISA KEV	**CVE-2020-1472**: added 2021-11-03, federal due date 2022-05-03	Known ransomware use	
Description	The remote domain controller is affected by an elevation of privilege flaw in the Netlogon Remote Protocol (MS-NRPC). An unauthenticated attacker with network access to the DC can establish a vulnerable Netlogon secure channel and set the computer account password of the domain controller, leading to full domain compromise.		
Solution	Apply the August 2020 (or later) cumulative update and confirm that enforcement mode (FullSecureChannelProtection = 1) is enabled. Because RB-DC02 runs an unsupported OS, plan to demote and replace it with a supported domain controller.		
Plugin output	`Nessus was able to establish a Netlogon secure channel with an all-zero client credential after 61 attempts.`		

3. Microsoft RDP RCE (CVE-2019-0708) (BlueKeep) (uncredentialed check) — CRITICAL | CVSS 9.8

Plugin ID	125313	**CVE**	CVE-2019-0708
Affected	10.20.2.15 (RB-HVAC-WS) tcp/3389		
CISA KEV	**CVE-2019-0708**: added 2021-11-03, federal due date 2022-05-03	Known ransomware use	
Description	The remote host is affected by a remote code execution vulnerability in Remote Desktop Services. An unauthenticated attacker can send specially crafted requests to the RDP service and execute arbitrary code. The flaw is wormable.		
Solution	Apply the May 2019 security update (KB4499175 / KB4499164 for Windows Server 2008 R2). Enable Network Level Authentication and block tcp/3389 from user VLANs. Move the HVAC console to a segmented building-systems VLAN.		
Plugin output	`Nessus detected the remote host is vulnerable by sending a crafted MS_T120 channel request.`		

4. Unsupported Windows OS (remote) — CRITICAL | CVSS 10.0

Plugin ID	108797 **CVE** N/A
Affected	10.20.1.11 (RB-DC02) - Windows Server 2012 R2 10.20.2.15 (RB-HVAC-WS) - Windows Server 2008 R2
CISA KEV	Not listed
Description	The remote version of Microsoft Windows is either missing a service pack or is no longer supported. Lack of support implies that no new security patches for the product will be released by the vendor. Windows Server 2012 R2 reached end of extended support on October 10, 2023, and Windows Server 2008 R2 on January 14, 2020.
Solution	Upgrade to a supported version of Windows. If an upgrade is blocked by a vendor dependency (HVAC software), isolate the host on its own VLAN with an allow-list firewall policy until it is replaced.
Plugin output	`RB-DC02    : Windows Server 2012 R2 Standard  (support ended 2023-10-10)` `RB-HVAC-WS : Windows Server 2008 R2 Standard SP1 (support ended 2020-01-14)`

5. Fortinet FortiOS SSL VPN Out-of-Bounds Write (FG-IR-24-015) — CRITICAL | CVSS 9.8

Plugin ID	190117 **CVE** CVE-2024-21762
Affected	203.0.113.10 (fw-do01) tcp/10443
CISA KEV	**CVE-2024-21762**: added 2024-02-09, federal due date 2024-02-16 | Known ransomware use
Description	The version of FortiOS running on the remote device is affected by an out-of-bounds write vulnerability in the SSL VPN daemon (sslvpnd). A remote, unauthenticated attacker can execute arbitrary code or commands via specially crafted HTTP requests.
Solution	Upgrade FortiOS to 7.2.7 or later (7.4.3 or later on the 7.4 branch). If an immediate upgrade is not possible, disable SSL VPN; disabling the web-mode portal alone is not sufficient. Review the device for signs of compromise per Fortinet guidance before returning it to service.

Plugin output	`Installed version : 7.2.6`
	`Fixed version     : 7.2.7`
	`SSL VPN portal    : enabled (tcp/10443)`

6. Citrix NetScaler ADC and Gateway Information Disclosure (CTX579459) (Citrix Bleed) — CRITICAL | CVSS 9.4

Plugin ID	183026 **CVE** CVE-2023-4966
Affected	203.0.113.25 (vdi-gw01) tcp/443
CISA KEV	**CVE-2023-4966**: added 2023-10-18, federal due date 2023-11-08 | Known ransomware use
Description	The remote NetScaler appliance configured as a Gateway (VPN virtual server, ICA proxy, RDP proxy) is affected by a buffer over-read. An unauthenticated attacker can read memory that contains valid session tokens and hijack authenticated sessions, bypassing MFA.
Solution	Upgrade to NetScaler ADC 13.1-49.15 or later. After upgrading, kill all active and persistent sessions (kill icaconnection -all, kill aaa session -all, kill rdp connection -all, clear lb persistentSessions).

Plugin output	`Installed version : 13.1-48.47`
	`Fixed version     : 13.1-49.15`
	`Gateway vServer   : vdi_gw_vs (enabled)`

7. SonicWall SonicOS Improper Access Control (SNWLID-2024-0015) — CRITICAL | CVSS 9.3

Plugin ID	206797	**CVE**	CVE-2024-40766
Affected	203.0.113.40 (fw-ae01) tcp/443		
CISA KEV	**CVE-2024-40766**: added 2024-09-09, federal due date 2024-09-30 | Known ransomware use		
Description	The remote SonicWall firewall is running a SonicOS version affected by an improper access control flaw in the management access and SSL VPN features. A remote attacker can gain unauthorized access to resources or crash the firewall. This flaw has been used for initial access in ransomware campaigns.		
Solution	Upgrade SonicOS to 7.0.1-5035 or later on Gen 7 devices. Restrict management to trusted internal addresses, disable WAN management, reset passwords for all local SSL VPN users, and enforce MFA for SSL VPN.		

Plugin output	`Installed version : 7.0.1-5030`
	`Fixed version : 7.0.1-5035`
	`WAN HTTPS management : enabled`		

8. Cisco IOS XE Software Web UI Privilege Escalation (cisco-sa-iosxe-webui-privesc-j22SaA4z) — CRITICAL | CVSS 10.0

Plugin ID	183891	**CVE**	CVE-2023-20198, CVE-2023-20273
Affected	10.20.0.1 (core-sw01) tcp/443		
CISA KEV	**CVE-2023-20198**: added 2023-10-16, federal due date 2023-10-20 **CVE-2023-20273**: added 2023-10-23, federal due date 2023-10-27		
Description	The Cisco IOS XE device has the HTTP/HTTPS server feature enabled and is running a vulnerable release. An unauthenticated attacker can create a privilege level 15 account and then use a second flaw to run commands as root. Implants were widely deployed through this pair of flaws in October 2023.		
Solution	Upgrade to IOS XE 17.6.6a or later. Until then, disable the web UI with 'no ip http server' and 'no ip http secure-server'. Check the running configuration for unknown local user accounts.		

Plugin output	`Installed version : 17.6.4`
	`Fixed version : 17.6.6a`
	`ip http secure-server : enabled`		

9. PaperCut NG/MF Multiple Vulnerabilities (ZDI-CAN-18987) — CRITICAL | CVSS 9.8

Plugin ID	174150	**CVE**	CVE-2023-27350
Affected	10.20.1.40 (RB-PRINT01) tcp/9191		
CISA KEV	**CVE-2023-27350**: added 2023-04-21, federal due date 2023-05-12 | Known ransomware use		
Description	The version of PaperCut MF installed on the remote host is affected by an improper access control flaw in the SetupCompleted class. An unauthenticated attacker can bypass authentication and execute arbitrary code as SYSTEM. CISA and FBI reported this flaw being exploited against the education sector.		
Solution	Upgrade PaperCut MF/NG to 20.1.7, 21.2.11, 22.0.9, or later. Block external access to tcp/9191 and tcp/9192 and restrict the admin console to IT management addresses.		

Plugin output	`Path : C:\Program Files\PaperCut MF\`
	`Installed version : 21.2.4`
	`Fixed version : 21.2.11`		

10. ConnectWise ScreenConnect < 23.9.8 Multiple Vulnerabilities — CRITICAL | CVSS 10.0

Plugin ID	190890	**CVE**	CVE-2024-1709, CVE-2024-1708
Affected	10.20.1.70 (RB-RMM01) tcp/8040		
CISA KEV	**CVE-2024-1709**: added 2024-02-22, federal due date 2024-02-29 | Known ransomware use **CVE-2024-1708**: added 2026-04-28, federal due date 2026-05-12 | Known ransomware use		
Description	The version of ConnectWise ScreenConnect on the remote host is affected by an authentication bypass using an alternate path (SetupWizard.aspx). An unauthenticated attacker can create an administrator account and push code to every managed endpoint. A related path traversal flaw (CVE-2024-1708) allows code execution.		
Solution	Upgrade ScreenConnect to 23.9.8 or later. Review the User.xml file and audit logs for unknown administrator accounts, and review sessions pushed to endpoints since the install date.		

Plugin output	`URL : http://10.20.1.70:8040/`
	`Installed version : 23.9.7.8804`
	`Fixed version : 23.9.8`		

11. Veeam Backup and Replication Deserialization RCE (KB4649) — CRITICAL | CVSS 9.8

Plugin ID	207999	**CVE**	CVE-2024-40711
Affected	10.20.1.60 (RB-VBR01) tcp/9401		
CISA KEV	**CVE-2024-40711**: added 2024-10-17, federal due date 2024-11-07 | Known ransomware use		
Description	The version of Veeam Backup & Replication installed on the remote host is affected by a deserialization of untrusted data flaw. An unauthenticated attacker can execute code on the backup server. This flaw has been used by ransomware operators to create local admin accounts and destroy backups before encryption.		
Solution	Upgrade Veeam Backup & Replication to 12.2.0.334 or later. Remove the backup server from the domain or place it in a separate management tier, and keep at least one immutable or offline backup copy.		

Plugin output	`Path : C:\Program Files\Veeam\Backup and Replication\`
	`Installed version : 12.1.2.172`
	`Fixed version : 12.2.0.334`		

12. Security Updates for Microsoft Outlook (March 2023) — CRITICAL | CVSS 9.8

Plugin ID	172529	**CVE**	CVE-2023-23397
Affected	10.20.5.0/24 - 9 of 41 staff workstations (STAFF-0112, STAFF-0118, STAFF-0131, +6)		
CISA KEV	**CVE-2023-23397**: added 2023-03-14, federal due date 2023-04-04		
Description	The Microsoft Outlook installation on the remote host is missing a security update. An attacker can send a message with an extended MAPI property containing a UNC path to an attacker-controlled SMB server. Outlook processes it on receipt, with no user interaction, and leaks the user's Net-NTLMv2 hash.		
Solution	Apply the March 2023 Office security updates through Microsoft 365 Apps update channels. Add users to the Protected Users group where possible and block outbound tcp/445 at the perimeter.		

Plugin output	`Product : Microsoft 365 Apps for enterprise (Semi-Annual Channel)`
	`Installed build : 16.0.15601.20526`
	`Fixed build : 16.0.15601.20578`		

13. Microsoft SharePoint Server Deserialization RCE (ToolShell) — CRITICAL | CVSS 9.8

Plugin ID	242281
CVE	CVE-2025-53770
Affected	10.20.1.25 (RB-SP01) tcp/443
CISA KEV	**CVE-2025-53770**: added 2025-07-20, federal due date 2025-07-21 | Known ransomware use
Description	The on-premises SharePoint Server installation is affected by a deserialization of untrusted data flaw. An unauthenticated attacker can execute code and steal the server's ASP.NET machine keys, which keeps access open even after patching.
Solution	Apply the July 2025 SharePoint security update (KB5002754 for SharePoint Server 2019). Enable AMSI in Full Mode with Defender Antivirus, then rotate ASP.NET machine keys and restart IIS after patching.

Plugin output	`Product : SharePoint Server 2019`
	`Installed build : 16.0.10417.20018`
	`Fixed build : 16.0.10417.20027`

14. Windows Server Update Service (WSUS) Remote Code Execution (October 2025 OOB) — CRITICAL | CVSS 9.8

Plugin ID	270115
CVE	CVE-2025-59287
Affected	10.20.1.30 (RB-WSUS01) tcp/8530
CISA KEV	**CVE-2025-59287**: added 2025-10-24, federal due date 2025-11-14
Description	The WSUS role on the remote host is affected by a deserialization of untrusted data flaw. An unauthenticated attacker can send a crafted event to the WSUS reporting web service and execute code as SYSTEM. A compromised WSUS server can be used to distribute malicious updates.
Solution	Apply the October 23, 2025 out-of-band update for Windows Server 2019 and reboot. If patching is delayed, disable the WSUS role or block inbound tcp/8530 and tcp/8531 at the host firewall.

Plugin output	`WSUS role : installed`
	`Listening ports : 8530/tcp, 8531/tcp`
	`Missing update : KB5070883`

15. Apache Tomcat 9.0.0.M1 < 9.0.99 Partial PUT RCE — CRITICAL | CVSS 9.8

Plugin ID	233431
CVE	CVE-2025-24813
Affected	10.20.1.50 (rb-app02) tcp/8080
CISA KEV	**CVE-2025-24813**: added 2025-04-01, federal due date 2025-04-22
Description	The version of Apache Tomcat on the remote host is affected by a path equivalence flaw in partial PUT handling. When writes are enabled for the default servlet and file-based session persistence is in use, an attacker can upload a serialized payload and execute code.
Solution	Upgrade Apache Tomcat to 9.0.99 or later. Set readonly=true on the default servlet and disable partial PUT support if it is not required.

Plugin output	`Installed version : 9.0.62`
	`Fixed version : 9.0.99`
	`Default servlet readonly : false`

16. PHP 8.1.x < 8.1.29 CGI Argument Injection (Windows) — CRITICAL | CVSS 9.8

Plugin ID	200162	**CVE**	CVE-2024-4577
Affected	10.20.3.12 (RHS-WEB01) tcp/80		
CISA KEV	**CVE-2024-4577**: added 2024-06-12, federal due date 2024-07-03 | Known ransomware use		
Description	The PHP installation on this Windows host runs in CGI mode and is affected by an argument injection flaw caused by Windows 'Best-Fit' character conversion. An unauthenticated attacker can pass options to php-cgi and execute code. XAMPP default configurations are affected.		
Solution	Upgrade PHP to 8.1.29, 8.2.20, 8.3.8, or later. Better: move the class website to the district's managed web hosting and remove XAMPP from the workstation.		

Plugin output	`Path : C:\xampp\php\`
	`Installed version : 8.1.10`
	`Fixed version : 8.1.29`		

High findings

17. MS17-010: Security Update for Microsoft Windows SMB Server (ETERNALBLUE) — HIGH | CVSS 8.8

Plugin ID	97833	**CVE**	CVE-2017-0144, CVE-2017-0145
Affected	10.20.2.15 (RB-HVAC-WS) tcp/445		
CISA KEV	**CVE-2017-0144**: added 2022-02-10, federal due date 2022-08-10 | Known ransomware use **CVE-2017-0145**: added 2022-02-10, federal due date 2022-08-10 | Known ransomware use		
Description	The remote Windows host is affected by multiple remote code execution flaws in SMBv1. An unauthenticated attacker can execute code with a crafted packet. WannaCry and NotPetya used these flaws to spread.		
Solution	Apply MS17-010 (KB4012212 for Windows Server 2008 R2) and disable SMBv1 (Set-SmbServerConfiguration -EnableSMB1Protocol $false).		
Plugin output	`Nessus sent a crafted SMBv1 transaction and received STATUS_INSUFF_SERVER_RESOURCES.`		

18. Windows Print Spooler Remote Code Execution (PrintNightmare) — HIGH | CVSS 8.8

Plugin ID	151440	**CVE**	CVE-2021-34527
Affected	10.20.1.10 (RB-DC01) tcp/445 10.20.1.11 (RB-DC02) tcp/445 10.20.1.40 (RB-PRINT01) tcp/445		
CISA KEV	**CVE-2021-34527**: added 2021-11-03, federal due date 2022-05-03 | Known ransomware use		
Description	The Print Spooler service on the remote host is affected by a remote code execution flaw. An authenticated user can install a malicious printer driver and run code as SYSTEM. On domain controllers this leads to domain compromise.		
Solution	Apply the July 2021 (or later) cumulative update and set RestrictDriverInstallationToAdministrators = 1. Disable the Print Spooler service on domain controllers and any server that does not print.		

Plugin output	`Print Spooler service : Running`
	`RestrictDriverInstallationToAdministrators : not set`
	`Point and Print NoWarningNoElevationOnInstall : 1`		

19. Microsoft Exchange Server Multiple Vulnerabilities (ProxyNotShell) — HIGH | CVSS 8.8

Plugin ID	165703	**CVE**	CVE-2022-41040, CVE-2022-41082
Affected	10.20.1.20 (RB-EXCH01) tcp/443		
CISA KEV	**CVE-2022-41040**: added 2022-09-30, federal due date 2022-10-21 | Known ransomware use **CVE-2022-41082**: added 2022-09-30, federal due date 2022-10-21 | Known ransomware use		
Description	The Exchange Server installation is affected by a server-side request forgery flaw that an authenticated attacker can chain with a PowerShell remote code execution flaw. Any mailbox credential is enough to start the chain.		
Solution	Apply the November 2022 Exchange Server Security Update (or later) for Exchange 2016 CU23. Exchange 2016 reached end of support in October 2025, so plan to move remaining mailboxes to Exchange Online or Exchange Server Subscription Edition.		

Plugin output	`Product : Exchange Server 2016 CU23`
	`Installed build : 15.1.2507.12`
	`Fixed build : 15.1.2507.16`		

20. OpenSSH < 9.8 RCE (regreSSHion) — HIGH | CVSS 8.1

Plugin ID	201218	**CVE**	CVE-2024-6387
Affected	10.20.1.80 (rb-web01) tcp/22		
CISA KEV	Not listed		
Description	The OpenSSH server on the remote host is affected by a signal handler race condition in sshd. An unauthenticated attacker may be able to execute code as root on glibc-based Linux systems. Exploitation takes many attempts but is practical.		
Solution	Install the Ubuntu security update for openssh-server (1:8.9p1-3ubuntu0.10 or later on 22.04). If patching is delayed, set LoginGraceTime 0 in sshd_config and restrict tcp/22 to the IT management VLAN.		

Plugin output	`Banner : SSH-2.0-OpenSSH_8.9p1 Ubuntu-3ubuntu0.6`
	`Installed package : 1:8.9p1-3ubuntu0.6`
	`Fixed package : 1:8.9p1-3ubuntu0.10`		

21. Windows SMB Client Improper Access Control (October 2025) — HIGH | CVSS 8.8

Plugin ID	268447	**CVE**	CVE-2025-33073
Affected	10.20.5.0/24 - 14 of 41 staff workstations		
CISA KEV	**CVE-2025-33073**: added 2025-10-20, federal due date 2025-11-10		
Description	The remote Windows host is missing a security update for the SMB client. An attacker who can coerce the host into authenticating to an attacker-controlled SMB server can reflect the authentication and gain SYSTEM privileges.		
Solution	Apply the June 2025 (or later) cumulative update and require SMB signing on clients and servers (see the 'SMB Signing not required' finding).		
Plugin output	`14 hosts missing KB5060842 or a later cumulative update. Oldest installed build: 22631.5262`		

22. 7-Zip < 24.09 Mark-of-the-Web Bypass — HIGH | CVSS 7.0

Plugin ID	214985	**CVE**	CVE-2025-0411
Affected	10.20.5.0/24 - 22 of 41 staff workstations		
CISA KEV	**CVE-2025-0411**: added 2025-02-06, federal due date 2025-02-27		
Description	The version of 7-Zip on the remote host does not carry the Mark-of-the-Web to files extracted from a crafted nested archive. A phishing attachment can then run without SmartScreen or Office Protected View warnings.		
Solution	Upgrade 7-Zip to 24.09 or later, or remove it and use the built-in Windows archive support. Deploy through Intune or SCCM; 7-Zip has no auto-update.		

Plugin output	`Path : C:\Program Files\7-Zip\`
	`Installed versions: 19.00 (9 hosts), 22.01 (13 hosts)`
	`Fixed version : 24.09`		

23. RARLAB WinRAR < 7.12 Directory Traversal — HIGH | CVSS 7.8

Plugin ID	241640	**CVE**	CVE-2025-6218
Affected	10.20.5.0/24 - 6 of 41 staff workstations		
CISA KEV	**CVE-2025-6218**: added 2025-12-09, federal due date 2025-12-30		
Description	The version of WinRAR on the remote host is affected by a directory traversal flaw. Extracting a crafted archive can write files outside the target folder, such as into the user's Startup folder, which leads to code execution at next logon.		
Solution	Upgrade WinRAR to 7.12 or later, or remove it from staff images if it is not licensed or required.		

Plugin output	`Path : C:\Program Files\WinRAR\`
	`Installed version : 6.24`
	`Fixed version : 7.12`		

24. Windows MSHTML Platform Spoofing (July 2024) — HIGH | CVSS 7.5

Plugin ID	201944	**CVE**	CVE-2024-38112
Affected	10.20.5.0/24 - 3 of 41 staff workstations (STAFF-0204, STAFF-0219, STAFF-0233)		
CISA KEV	**CVE-2024-38112**: added 2024-07-09, federal due date 2024-07-30		
Description	The remote Windows host is missing the July 2024 security update for MSHTML. A crafted .url file can open a page in the retired Internet Explorer engine and lead the user to run a disguised file.		
Solution	Apply the July 2024 (or later) cumulative update. These three hosts have not reported to WSUS in over 90 days; investigate the update agent.		
Plugin output	`Last successful update scan : 2026-06-18` `Missing update : KB5040442 (or later cumulative update)`		

25. HTTP/2 Rapid Reset Denial of Service — HIGH | CVSS 7.5

Plugin ID	187100	**CVE**	CVE-2023-44487
Affected	10.20.1.80 (rb-web01) tcp/443		
CISA KEV	**CVE-2023-44487**: added 2023-10-10, federal due date 2023-10-31		
Description	The remote web server supports HTTP/2 and is running a version affected by the Rapid Reset attack. A remote attacker can open and cancel streams at high rate and exhaust server resources, taking the public website offline.		
Solution	Upgrade nginx to 1.25.3 or a distribution package that includes the fix, or set keepalive_requests and http2_max_concurrent_streams to conservative values. Upstream DDoS protection also mitigates this.		
Plugin output	`Server header : nginx/1.18.0 (Ubuntu)` `ALPN : h2, http/1.1`		

26. SSL Medium Strength Cipher Suites Supported (SWEET32) — HIGH | CVSS 7.5

Plugin ID	42873	**CVE**	CVE-2016-2183
Affected	10.20.1.40 (RB-PRINT01) tcp/9192 10.20.2.15 (RB-HVAC-WS) tcp/3389 10.20.1.11 (RB-DC02) tcp/636		
CISA KEV	Not listed		
Description	The remote host supports SSL ciphers that use 64-bit block ciphers (3DES). An attacker on the same network who can capture a long-lived session can recover plaintext with a birthday attack.		
Solution	Disable 3DES and other 64-bit block ciphers in the SChannel configuration (or application TLS settings) and allow only AES-GCM suites with TLS 1.2 or later.		

Plugin output	`Medium Strength Ciphers (> 64-bit and < 112-bit key, or 3DES)`
	`ECDHE-RSA-DES-CBC3-SHA Kx=ECDH Au=RSA Enc=3DES-CBC(168) Mac=SHA1`
	`DES-CBC3-SHA Kx=RSA Au=RSA Enc=3DES-CBC(168) Mac=SHA1`		

27. SNMP Agent Default Community Name (public) — HIGH | CVSS 7.5

Plugin ID	41028	**CVE**	CVE-1999-0517
Affected	10.20.0.1 (core-sw01) udp/161 10.20.1.40 (RB-PRINT01) udp/161 10.20.2.15 (RB-HVAC-WS) udp/161		
CISA KEV	Not listed		
Description	It is possible to obtain the default community name of the remote SNMP server. An attacker can read the device configuration, routing tables, and interface details, and on core-sw01 the community is read-write.		
Solution	Disable SNMP if it is not used. Otherwise, move to SNMPv3 with authPriv, or at minimum change the community string and limit access with an ACL to the monitoring server.		

Plugin output	`The remote SNMP server replies to the following default community strings:`
	`  public  (core-sw01: RW)`
	`  private (core-sw01: RW)`		

Medium findings

28. SMB Signing not required — MEDIUM | CVSS 5.3

Plugin ID	57608	**CVE**	N/A
Affected	10.20.1.40 (RB-PRINT01) tcp/445 10.20.1.60 (RB-VBR01) tcp/445 10.20.1.70 (RB-RMM01) tcp/445 10.20.2.15 (RB-HVAC-WS) tcp/445 10.20.5.0/24 - 41 of 41 staff workstations		
CISA KEV	Not listed		
Description	Signing is not required on the remote SMB server. An unauthenticated attacker on the network can carry out man-in-the-middle and NTLM relay attacks against the SMB server.		
Solution	Enforce message signing with Group Policy: 'Microsoft network server: Digitally sign communications (always)' and the matching client setting. Test against copiers and older NAS devices first.		
Plugin output	`Host does not require SMB signing (SMBv2 negotiate: signing enabled, not required).`		

29. Windows NTLM Hash Disclosure Spoofing (November 2024) — MEDIUM | CVSS 6.5

Plugin ID	211469	**CVE**	CVE-2024-43451
Affected	10.20.5.0/24 - 3 of 41 staff workstations (STAFF-0204, STAFF-0219, STAFF-0233)		
CISA KEV	**CVE-2024-43451**: added 2024-11-12, federal due date 2024-12-03		
Description	The remote Windows host is missing a security update. Minimal interaction with a crafted file, such as a single click or right-click, can disclose the user's NTLMv2 hash to a remote attacker.		
Solution	Apply the November 2024 (or later) cumulative update. Block outbound SMB (tcp/445) at the perimeter.		
Plugin output	`Missing update : KB5046617 (or later cumulative update)`		

30. SSL Certificate Cannot Be Trusted — MEDIUM | CVSS 6.5

Plugin ID	51192	**CVE**	N/A
Affected	10.20.1.40 (RB-PRINT01) tcp/9192 10.20.1.60 (RB-VBR01) tcp/9443 10.20.0.1 (core-sw01) tcp/443 10.20.1.50 (rb-app02) tcp/8443		
CISA KEV	Not listed		
Description	The X.509 certificate chain for this service is not signed by a recognized certificate authority. Users who learn to click through certificate warnings cannot tell a real service from a man-in-the-middle.		
Solution	Issue certificates from the district's internal CA (or a public CA for external services) and deploy the CA root to managed devices.		

Plugin output	`Subject : CN=RB-PRINT01`
	`Issuer  : CN=RB-PRINT01 (self-signed)`
	`Not After : 2024-08-14 (expired)`		

31. TLS Version 1.0 Protocol Detection — MEDIUM | CVSS 6.5

Plugin ID	104743	**CVE**	N/A
Affected	10.20.1.11 (RB-DC02) tcp/636 10.20.1.20 (RB-EXCH01) tcp/443 10.20.2.15 (RB-HVAC-WS) tcp/3389 203.0.113.40 (fw-ae01) tcp/443		
CISA KEV	Not listed		
Description	The remote service accepts connections encrypted using TLS 1.0, which has known design flaws. PCI DSS and most current guidance require disabling it.		
Solution	Disable TLS 1.0 and 1.1 and enable TLS 1.2 and 1.3. On Windows, set the SChannel protocol registry keys or use IIS Crypto; confirm SIS and finance integrations support TLS 1.2 first.		
Plugin output	`TLSv1.0 is enabled and the server supports at least one cipher.`		

32. Unencrypted Telnet Server — MEDIUM | CVSS 6.5

Plugin ID	42263	**CVE**	N/A
Affected	10.20.0.1 (core-sw01) tcp/23		
CISA KEV	Not listed		
Description	The remote host is running a Telnet server over an unencrypted channel. Logins, passwords, and commands are sent in cleartext and can be captured by anyone on the path.		
Solution	Disable Telnet ('transport input ssh' on all VTY lines) and use SSH version 2.		
Plugin output	`Banner: User Access Verification\r\nUsername:`		

33. SSH Terrapin Prefix Truncation Weakness — MEDIUM | CVSS 5.9

Plugin ID	187315	**CVE**	CVE-2023-48795
Affected	10.20.1.80 (rb-web01) tcp/22 10.20.1.50 (rb-app02) tcp/22 10.20.0.1 (core-sw01) tcp/22		
CISA KEV	Not listed		
Description	The remote SSH server supports ChaCha20-Poly1305 or CBC ciphers with Encrypt-then-MAC and does not support strict key exchange. A man-in-the-middle can drop messages at the start of the session and downgrade security features.		
Solution	Update the SSH server to a release that supports strict KEX (OpenSSH 9.6 or vendor backport), or disable chacha20-poly1305@openssh.com and *-etm@openssh.com MACs.		
Plugin output	`Supports following ChaCha20-Poly1305 Client to Server algorithm : chacha20-poly1305@openssh.com` `Strict KEX : not supported`		

34. Apache Tomcat Default Files — MEDIUM | CVSS 5.3

Plugin ID	12085	**CVE**	N/A
Affected	10.20.1.50 (rb-app02) tcp/8080		
CISA KEV	Not listed		
Description	The default error pages, documentation, and example web applications are installed on the remote Tomcat server. They disclose the exact version and the examples contain known weaknesses.		
Solution	Delete the docs, examples, host-manager, and manager applications from webapps/ and configure custom error pages.		

Plugin output	`The following default files were found :`
	`  /examples/servlets/index.html`
	`  /docs/`
	`  /manager/html (HTTP 401)`		

35. HTTP TRACE / TRACK Methods Allowed — MEDIUM | CVSS 5.3

Plugin ID	11213	**CVE**	N/A
Affected	10.20.1.40 (RB-PRINT01) tcp/9191 10.20.3.12 (RHS-WEB01) tcp/80		
CISA KEV	Not listed		
Description	The remote web server supports the TRACE and/or TRACK methods, which echo the request back to the client and can expose headers such as cookies in cross-site tracing attacks.		
Solution	Disable TRACE and TRACK in the web server configuration (TraceEnable off for Apache).		
Plugin output	`TRACE /Nessus123456.html HTTP/1.1 -> HTTP/1.1 200 OK (request echoed)`		

36. DNS Server Cache Snooping Remote Information Disclosure — MEDIUM | CVSS 5.3

Plugin ID	12217	**CVE**	N/A
Affected	10.20.1.10 (RB-DC01) udp/53 10.20.1.11 (RB-DC02) udp/53		
CISA KEV	Not listed		
Description	The remote DNS server answers non-recursive queries for domains it does not host. An attacker can find out which sites internal users have visited recently.		
Solution	Restrict recursion to internal clients and disable non-recursive answers from cache for external sources.		
Plugin output	`Nessus sent a non-recursive query for 'www.google.com' and received 1 answer from cache.`		

Low findings

37. SSH Weak Key Exchange Algorithms Enabled — LOW | CVSS 3.7

Plugin ID	153953	**CVE**	N/A
Affected	10.20.0.1 (core-sw01) tcp/22 10.20.1.50 (rb-app02) tcp/22		
CISA KEV	Not listed		
Description	The remote SSH server allows key exchange algorithms that RFC 9142 marks as SHOULD NOT or MUST NOT, such as diffie-hellman-group1-sha1 and diffie-hellman-group-exchange-sha1.		
Solution	Remove the weak algorithms from the server's KexAlgorithms list ('ip ssh dh min size 2048' and 'ip ssh server algorithm kex' on IOS XE).		

Plugin output	`diffie-hellman-group1-sha1`
	`diffie-hellman-group14-sha1`
	`diffie-hellman-group-exchange-sha1`		

38. SSH Weak MAC Algorithms Enabled — LOW | CVSS 2.6

Plugin ID	71049	**CVE**	N/A
Affected	10.20.0.1 (core-sw01) tcp/22		
CISA KEV	Not listed		
Description	The remote SSH server is configured to allow MD5 or 96-bit MAC algorithms.		
Solution	Disable MD5 and 96-bit MAC algorithms; allow hmac-sha2-256 and hmac-sha2-512.		

Plugin output	`hmac-md5`
	`hmac-md5-96`
	`hmac-sha1-96`		

39. SSH Server CBC Mode Ciphers Enabled — LOW | CVSS 2.6

Plugin ID	70658	**CVE**	N/A
Affected	10.20.0.1 (core-sw01) tcp/22 10.20.2.15 (RB-HVAC-WS) tcp/22		
CISA KEV	Not listed		
Description	The SSH server allows Cipher Block Chaining (CBC) encryption, which may let an attacker recover plaintext from the ciphertext under specific conditions.		
Solution	Disable CBC mode ciphers and allow CTR or GCM ciphers.		

Plugin output	`aes128-cbc`
	`aes256-cbc`
	`3des-cbc`		

40. Web Server Transmits Cleartext Credentials — LOW | CVSS 2.6

Plugin ID	26194	**CVE**	N/A
Affected	10.20.3.12 (RHS-WEB01) tcp/80 10.20.2.15 (RB-HVAC-WS) tcp/80		
CISA KEV	Not listed		
Description	The remote web server contains a form with a password field that submits over plain HTTP. Credentials can be captured on the network.		
Solution	Serve the login form and its target over HTTPS only, and redirect HTTP to HTTPS.		
Plugin output	`Page : /admin/login.php` `Destination : http://10.20.3.12/admin/auth.php`		

41. ICMP Timestamp Request Remote Date Disclosure — LOW | CVSS 2.1

Plugin ID	10114	**CVE**	CVE-1999-0524
Affected	10.20.2.15 (RB-HVAC-WS) 10.20.1.11 (RB-DC02) 10.20.0.1 (core-sw01)		
CISA KEV	Not listed		
Description	The remote host answers ICMP timestamp requests, which lets an attacker learn the date set on the target. This can help defeat time-based authentication protocols.		
Solution	Filter ICMP timestamp requests (13) and replies (14) at the host or network firewall.		
Plugin output	`The difference between the local and remote clocks is 2 seconds.`		